Option D: Ransomware Intelligence Report

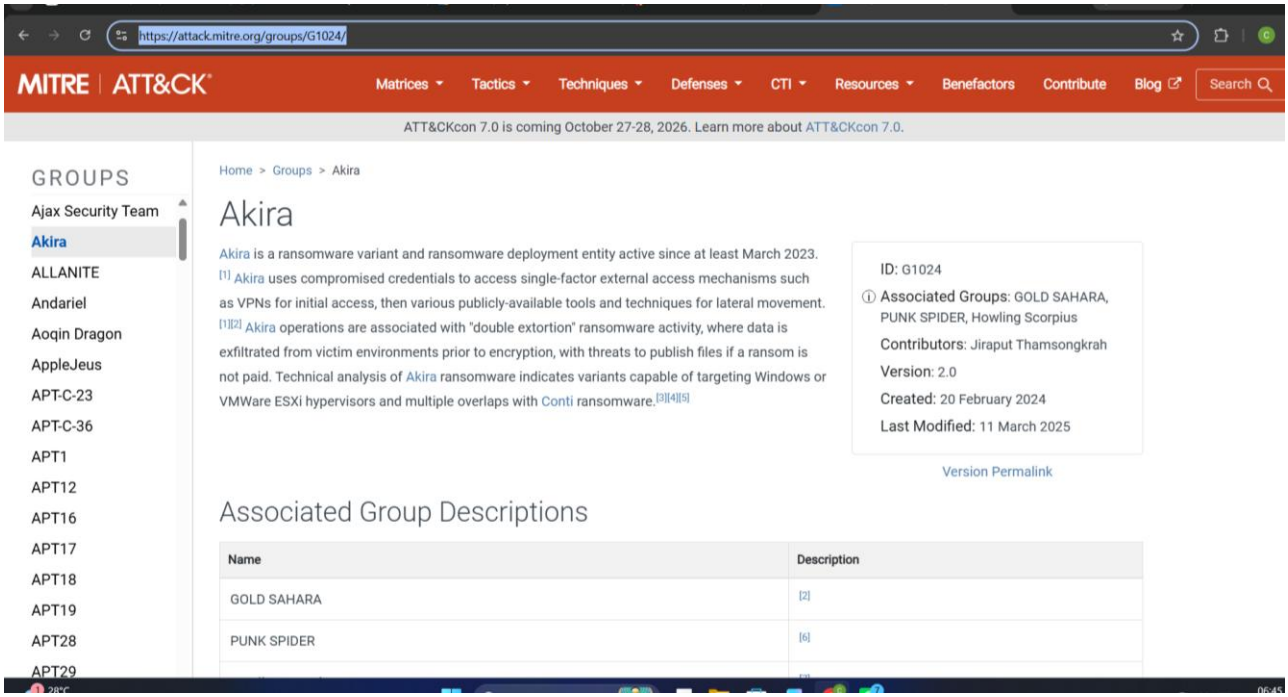
Name :- CHETNA SOLANKI

Date:- 28/07/2026

Ransomware Intelligence Report: Akira Ransomware

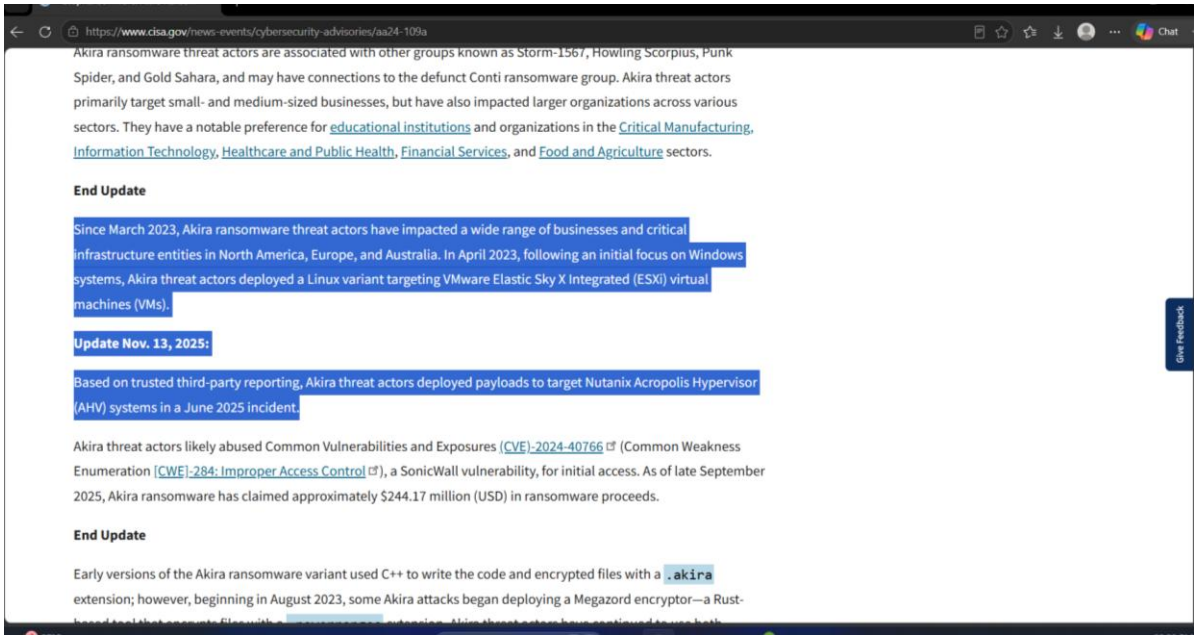
1. Overview

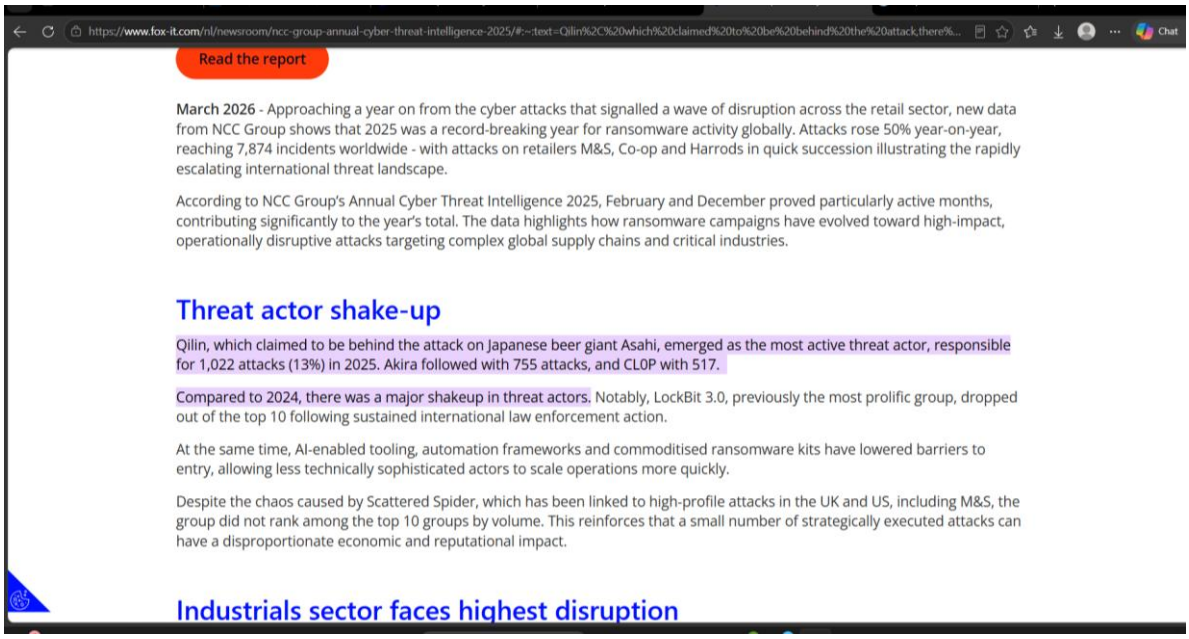
Akira is a Ransomware-as-a-Service (RaaS) operation that first appeared in March 2023. The ransomware is operated through an affiliate-based model, where affiliates conduct attacks using Akira ransomware. Known names associated with the Akira operation include GOLD SAHARA, PUNK SPIDER, and Howling Scorpius.



2. Timeline & Recent Activity

Date	Activity
March 2023	Akira ransomware activity was first observed.
April 2023	A Linux variant began targeting VMware ESXi virtual machines.
2024	Akira continued expanding its ransomware operation and virtualization targeting.
June 2025	Akira was reported targeting Nutanix AHV virtual machine disk files.
November 2025	FBI/CISA and partner agencies updated their Akira advisory with recent IOCs and TTPs.
2025	NCC Group recorded 755 Akira attacks.





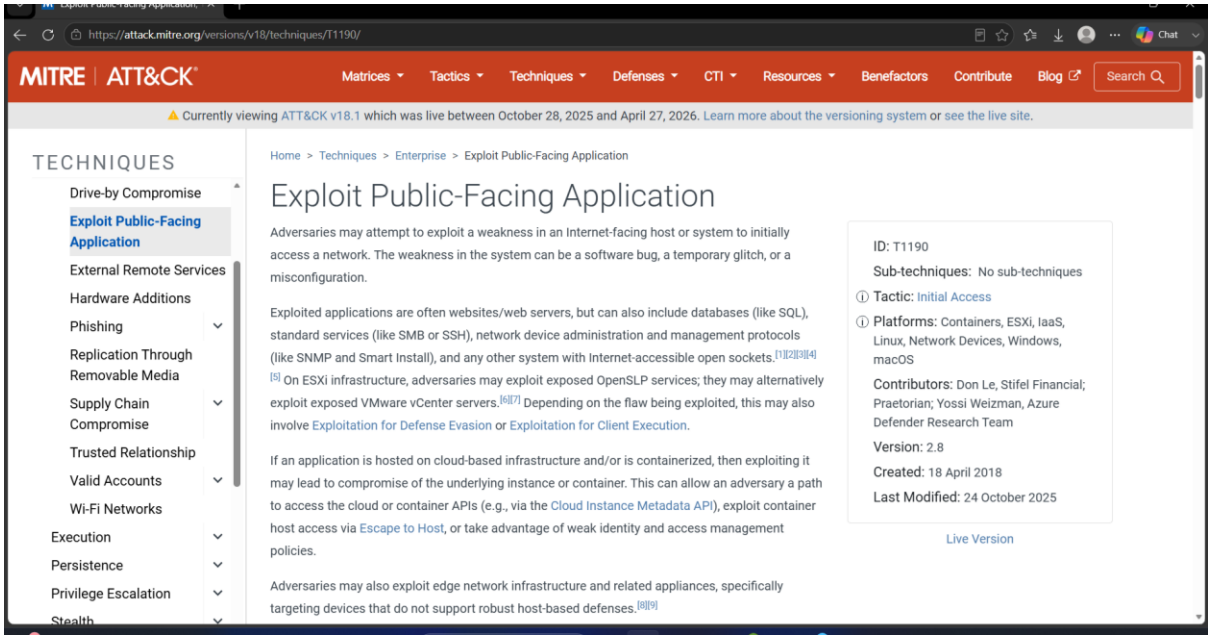
3.Initial access

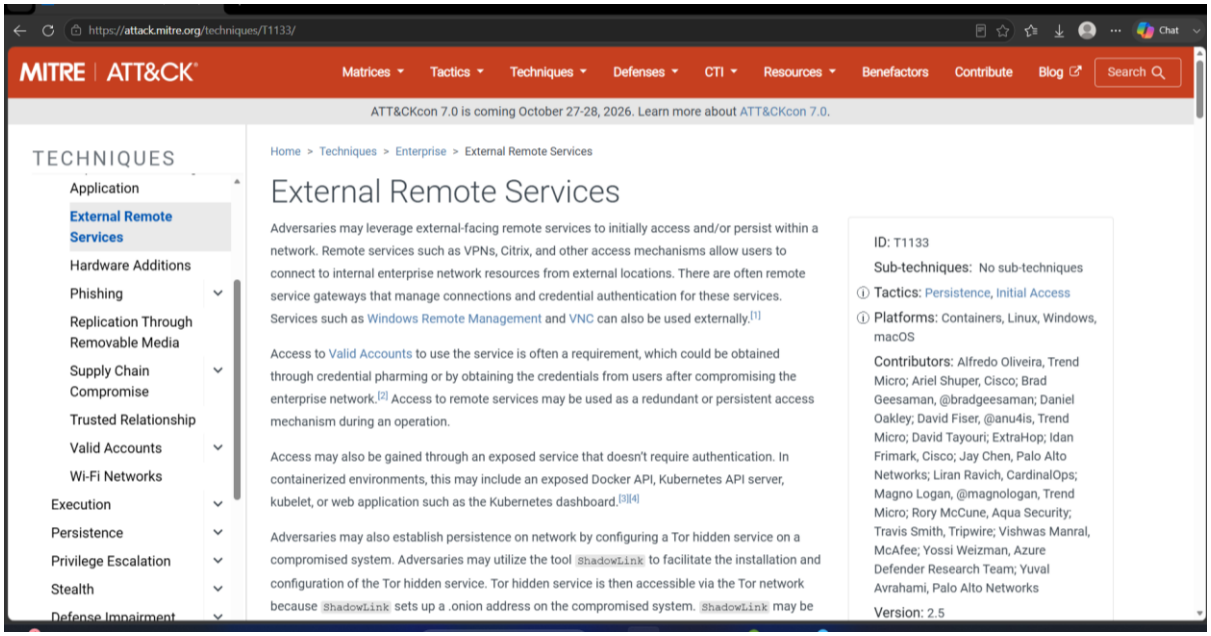
Akira attackers commonly gain initial access to victim networks through compromised valid accounts, external remote services such as VPN, and exploitation of public-facing applications. These methods allow attackers to enter

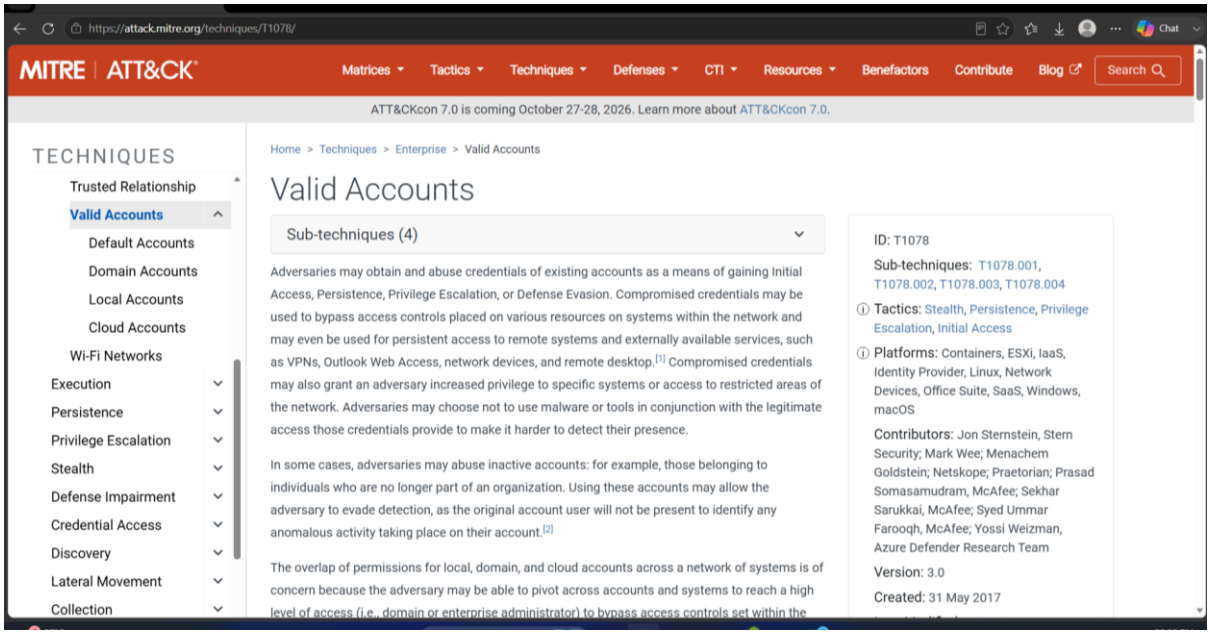
the organization’s network before moving laterally and deploying the ransomware.

Common Entry Points

Entry Point	Description
Valid Accounts (T1078)	Attackers use stolen or compromised usernames and passwords.
External Remote Services (T1133)	Attackers abuse remote access services such as VPN.
Exploit Public-Facing Application (T1190)	Attackers exploit vulnerabilities in internet-facing applications or devices.


https://attack.mitre.org/versions/v18/techniques/T1190/
MITRE | ATT&CK
Matrices
Tactics
Techniques
Defenses
CTI
Resources
Benefactors
Contribute
Blog
Search
Currently viewing ATT&CK v18.1 which was live between October 28, 2025 and April 27, 2026. Learn more about the versioning system or see the live site.
TECHNIQUES
Drive-by Compromise
Exploit Public-Facing Application
External Remote Services
Hardware Additions
Phishing
Replication Through Removable Media
Supply Chain Compromise
Trusted Relationship
Valid Accounts
Wi-Fi Networks
Execution
Persistence
Privilege Escalation
Stealth
Home > Techniques > Enterprise > Exploit Public-Facing Application
Exploit Public-Facing Application
Adversaries may attempt to exploit a weakness in an Internet-facing host or system to initially access a network. The weakness in the system can be a software bug, a temporary glitch, or a misconfiguration.
Exploited applications are often websites/web servers, but can also include databases (like SQL), standard services (like SMB or SSH), network device administration and management protocols (like SNMP and Smart Install), and any other system with Internet-accessible open sockets.[1][2][3][4][5] On ESXi infrastructure, adversaries may exploit exposed OpenSLP services; they may alternatively exploit exposed VMware vCenter servers.[6][7] Depending on the flaw being exploited, this may also involve Exploitation for Defense Evasion or Exploitation for Client Execution.
If an application is hosted on cloud-based infrastructure and/or is containerized, then exploiting it may lead to compromise of the underlying instance or container. This can allow an adversary a path to access the cloud or container APIs (e.g., via the Cloud Instance Metadata API), exploit container host access via Escape to Host, or take advantage of weak identity and access management policies.
Adversaries may also exploit edge network infrastructure and related appliances, specifically targeting devices that do not support robust host-based defenses.[8][9]
ID: T1190
Sub-techniques: No sub-techniques
Tactic: Initial Access
Platforms: Containers, ESXi, IaaS, Linux, Network Devices, Windows, macOS
Contributors: Don Le, Stifel Financial; Praetorian; Yossi Weizman, Azure Defender Research Team
Version: 2.8
Created: 18 April 2018
Last Modified: 24 October 2025
Live Version


https://attack.mitre.org/techniques/T1133/
MITRE | ATT&CK
Matrices
Tactics
Techniques
Defenses
CTI
Resources
Benefactors
Contribute
Blog
Search
ATT&CKcon 7.0 is coming October 27-28, 2026. Learn more about ATT&CKcon 7.0.
TECHNIQUES
Application
External Remote Services
Hardware Additions
Phishing
Replication Through Removable Media
Supply Chain Compromise
Trusted Relationship
Valid Accounts
Wi-Fi Networks
Execution
Persistence
Privilege Escalation
Stealth
Defense Impairment
Home > Techniques > Enterprise > External Remote Services
External Remote Services
Adversaries may leverage external-facing remote services to initially access and/or persist within a network. Remote services such as VPNs, Citrix, and other access mechanisms allow users to connect to internal enterprise network resources from external locations. There are often remote service gateways that manage connections and credential authentication for these services. Services such as Windows Remote Management and VNC can also be used externally.[1]
Access to Valid Accounts to use the service is often a requirement, which could be obtained through credential pharming or by obtaining the credentials from users after compromising the enterprise network.[2] Access to remote services may be used as a redundant or persistent access mechanism during an operation.
Access may also be gained through an exposed service that doesn't require authentication. In containerized environments, this may include an exposed Docker API, Kubernetes API server, kubelet, or web application such as the Kubernetes dashboard.[3][4]
Adversaries may also establish persistence on network by configuring a Tor hidden service on a compromised system. Adversaries may utilize the tool ShadowLink to facilitate the installation and configuration of the Tor hidden service. Tor hidden service is then accessible via the Tor network because ShadowLink sets up a .onion address on the compromised system. ShadowLink may be
ID: T1133
Sub-techniques: No sub-techniques
Tactics: Persistence, Initial Access
Platforms: Containers, Linux, Windows, macOS
Contributors: Alfredo Oliveira, Trend Micro; Ariel Shuper, Cisco; Brad Geesaman, @bradgeesaman; Daniel Oakley; David Fiser, @anu4is, Trend Micro; David Tayouri; ExtraHop; Idan Frimark, Cisco; Jay Chen, Palo Alto Networks; Liran Ravich, CardinalOps; Magno Logan, @magnologan, Trend Micro; Rory McCune, Aqua Security; Travis Smith, Tripwire; Vishwas Manral, McAfee; Yossi Weizman, Azure Defender Research Team; Yuval Avrahami, Palo Alto Networks
Version: 2.5



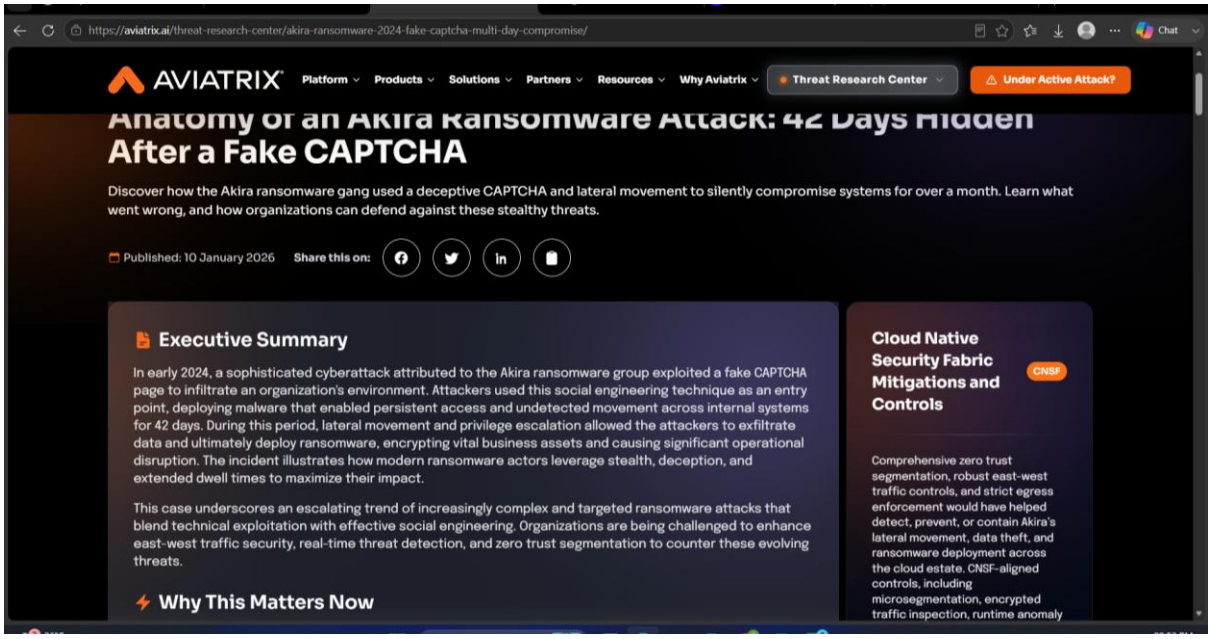
4. Encryption

Akira uses encryption algorithms such as ChaCha20 or KCipher2 to encrypt victim files. The encryption keys are protected using RSA-4096/RSA-4098. After encryption, affected files may receive the .akira extension. The ransomware also creates a ransom note named akira_readme.txt, which provides instructions for contacting the attackers and warns the victim about the consequences of not paying the ransom.

5. Double Extortion

Akira uses a double-extortion strategy. Attackers steal sensitive data from victims before or during the encryption process. The stolen data is then used as additional pressure to force the victim to pay the ransom. Akira also operates a

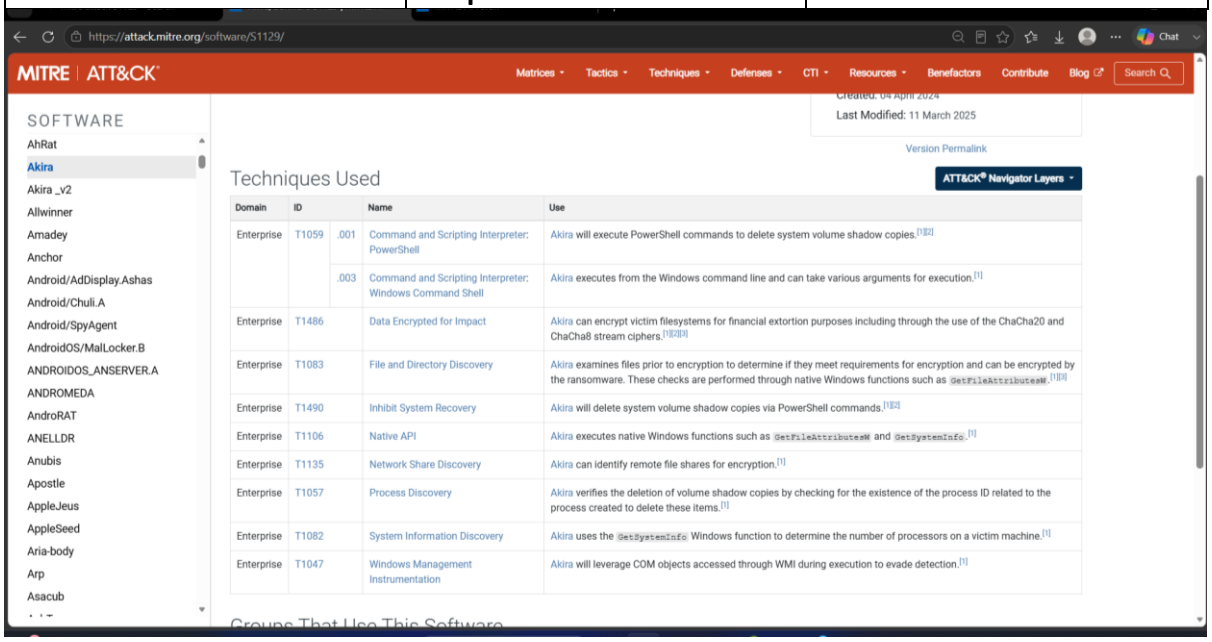
data-leak site where information from non-paying victims may be published.



6.TTPs & MITRE ATT&CK Mapping

Attack Stage	Akira Activity	MITRE ATT&CK Technique
Initial Access	Compromised accounts / VPN access	T1078 – Valid Accounts / T1133 – External Remote Services
Execution	PowerShell and command-line activity	T1059.001 – PowerShell
Privilege Escalation	Obtaining higher privileges	T1068 – Exploitation for Privilege Escalation
Discovery	Discovering systems, processes	T1082 – System Information

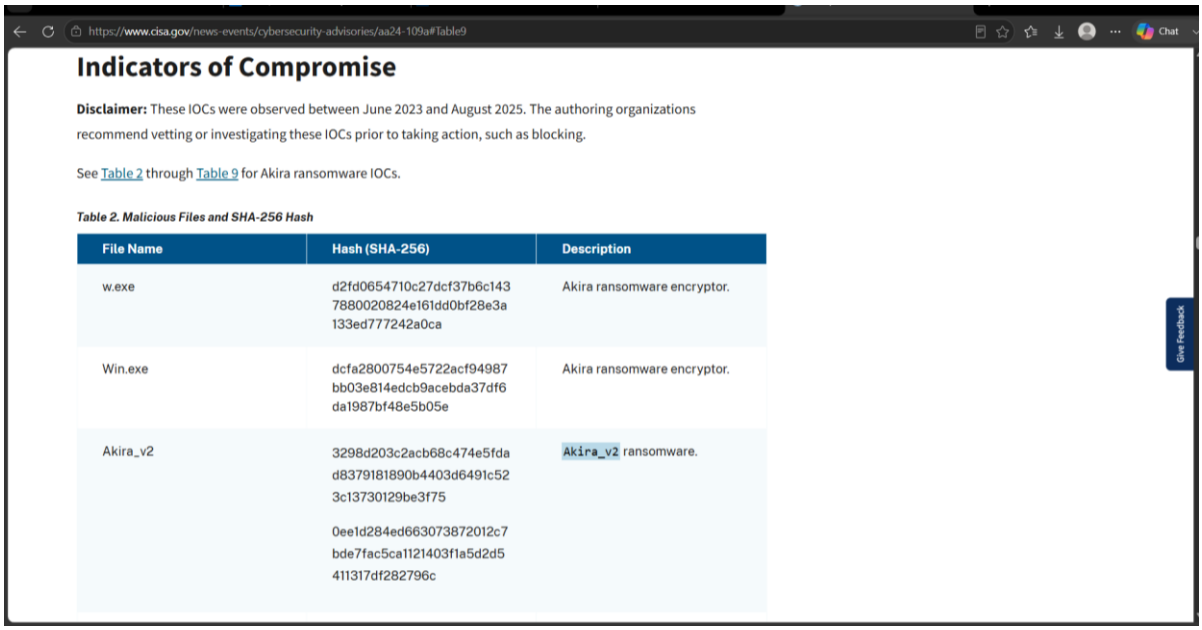
	and network shares	Discovery, T1057 – Process Discovery, T1135 – Network Share Discovery
Credential Access	Credential dumping	T1003 – OS Credential Dumping
Lateral Movement	Moving through remote services	T1021 – Remote Services
Exfiltration	Stealing victim data	T1041 – Exfiltration Over C2 Channel
Impact	Encrypting files	T1486 – Data Encrypted for Impact
Recovery Inhibition	Deleting backups/shadow copies	T1490 – Inhibit System Recovery



7.Indicators of Compromise(IOCs)

Indicators of Compromise (IOCs) are technical artifacts that help security teams identify Akira ransomware activity. These include malicious IP addresses, domains, malware file hashes, and the ransom note filename akira_readme.txt. Security teams should use the latest official IOC lists from CISA/FBI or trusted threat-intelligence providers.

Hash (screenshot)



https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-109a#Table9

Indicators of Compromise

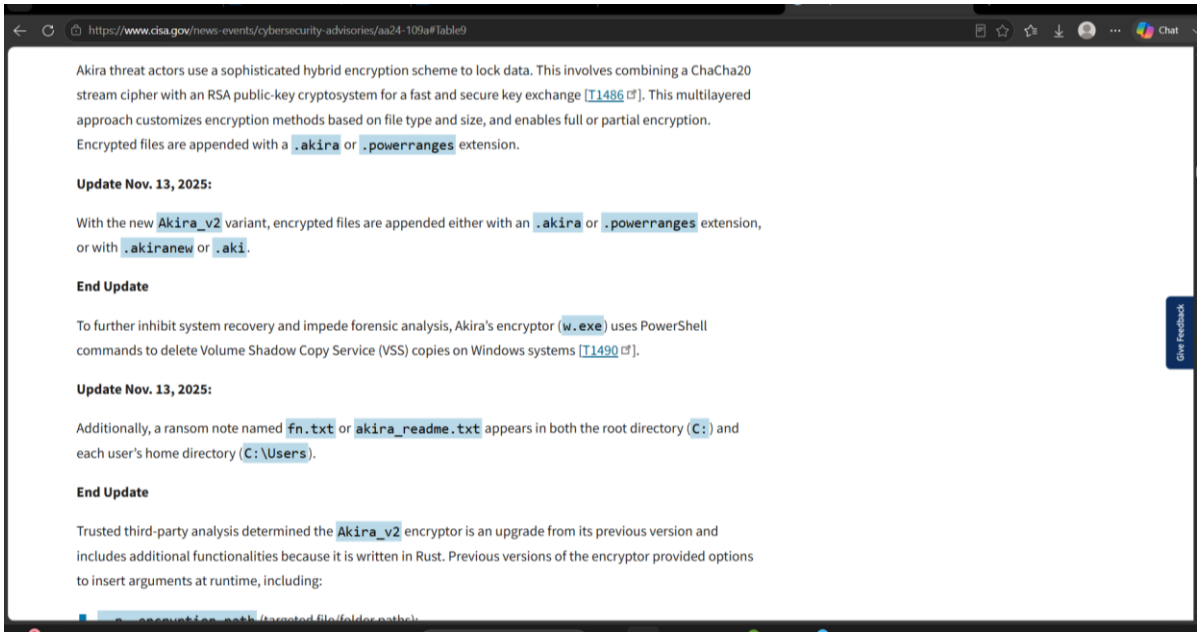
Disclaimer: These IOCs were observed between June 2023 and August 2025. The authoring organizations recommend vetting or investigating these IOCs prior to taking action, such as blocking.

See Table 2 through Table 9 for Akira ransomware IOCs.

Table 2. Malicious Files and SHA-256 Hash

File Name	Hash (SHA-256)	Description
w.exe	d2fd0654710c27dcf37b6c143 7880020824e161dd0bf28e3a 133ed777242a0ca	Akira ransomware encryptor.
Win.exe	dcfa2800754e5722acf94987 bb03e814edcb9acebda37df6 da1987bf48e5b05e	Akira ransomware encryptor.
Akira_v2	3298d203c2acb68c474e5fda d8379181890b4403d6491c52 3c13730129be3f75 0ee1d284ed663073872012c7 bde7fac5ca1121403f1a5d2d5 411317df282796c	`Akira_v2` ransomware.

Ransom Note(Screenshot)



https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-109a#Table9

Akira threat actors use a sophisticated hybrid encryption scheme to lock data. This involves combining a ChaCha20 stream cipher with an RSA public-key cryptosystem for a fast and secure key exchange [T1486]. This multilayered approach customizes encryption methods based on file type and size, and enables full or partial encryption. Encrypted files are appended with a `.akira` or `.powerranges` extension.

Update Nov. 13, 2025:

With the new `Akira_v2` variant, encrypted files are appended either with an `.akira` or `.powerranges` extension, or with `.akiranew` or `.aki`.

End Update

To further inhibit system recovery and impede forensic analysis, Akira's encryptor (`w.exe`) uses PowerShell commands to delete Volume Shadow Copy Service (VSS) copies on Windows systems [T1490].

Update Nov. 13, 2025:

Additionally, a ransom note named `fn.txt` or `akira_readme.txt` appears in both the root directory (`C:`) and each user's home directory (`C:\Users`).

End Update

Trusted third-party analysis determined the `Akira_v2` encryptor is an upgrade from its previous version and includes additional functionalities because it is written in Rust. Previous versions of the encryptor provided options to insert arguments at runtime, including:

Infection chain diagram(screenshot)



8.Detection & Mitigation

Akira ransomware can be detected before encryption by monitoring unusual VPN or RDP logins, suspicious PowerShell or command-line activity, large data transfers (data exfiltration), deletion of Volume Shadow Copies, and the creation of suspicious processes. Early detection using EDR and SIEM tools can help stop the attack before files are encrypted.

Mitigation:-

The following security measures can help prevent Akira ransomware attacks:

- Disable or restrict RDP if it is not required.
- Apply the latest security patches and software updates.
- Enable Multi-Factor Authentication (MFA) for VPN and remote access.
- Enable LSA Protection to protect user credentials.
- Use Endpoint Detection and Response (EDR).
- Keep offline or immutable backups.
- Monitor network activity and privileged user accounts regularly.

9.References

MITRE ATTECK Profile for Akira ransomware(S1129):-
https://attack.mitre.org/groups/G1024/

Detail :- https://www.cisa.gov/news-events/cybersecurity-advisories/aa24-109a

MITRE ATTECK Mapping:-

https://attack.mitre.org/software/S1129/